



■ Pruebas de penetración

- 2.3.1 Explotación de servicios web

Contenidos

- Hacking Web.
- OWASP TOP 10.
- .
- Reconocimiento
- Técnicas de hacking web.

A black and white photograph of a man in a suit holding a tablet, standing in a modern office with glass partitions and a desk with a coffee cup. The image is overlaid with a blue square on the left and a grey rectangle on the right.

01

Hacking web

Introducción

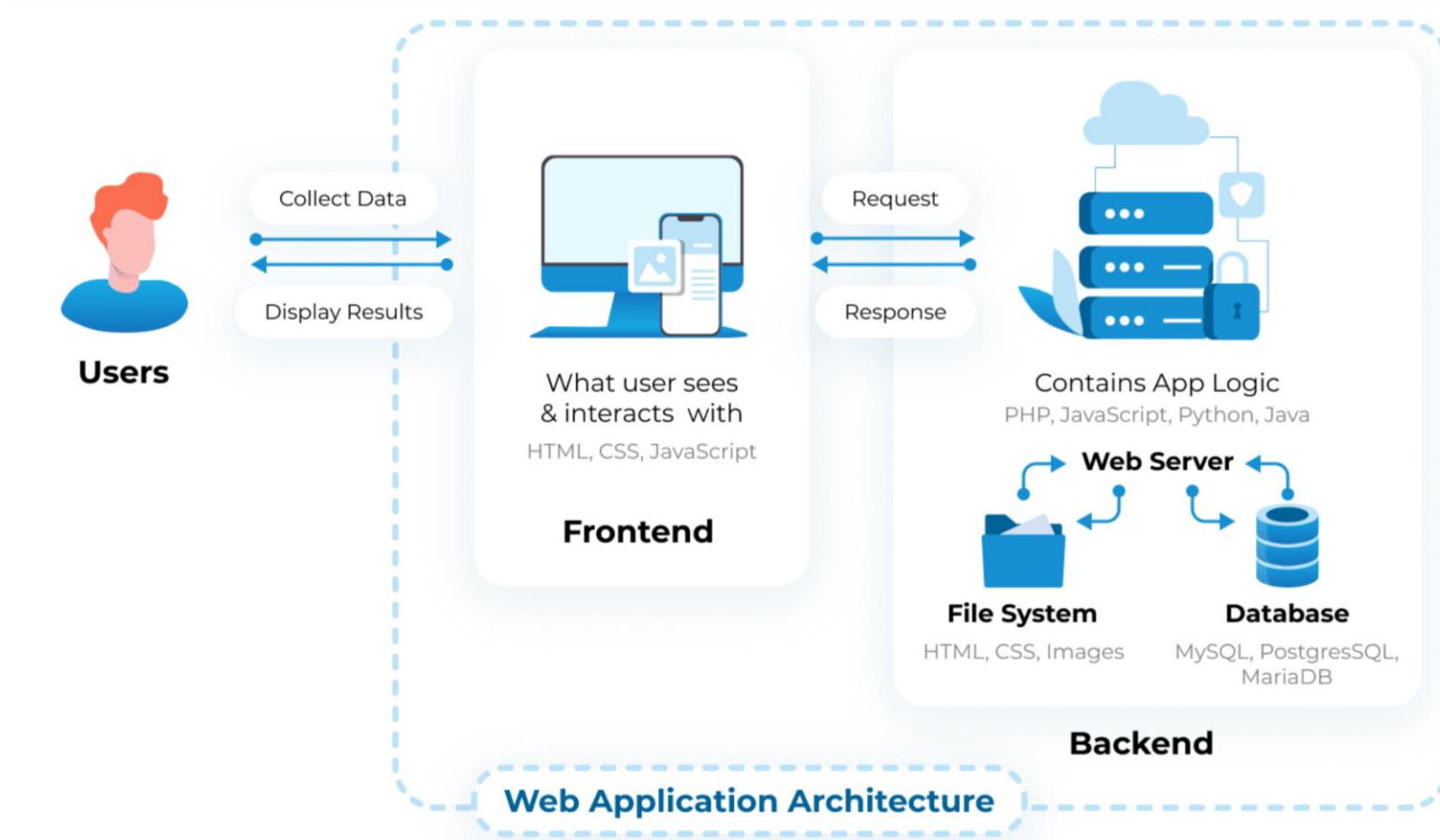
- Es ampliamente conocida la importancia de las aplicaciones web en el mundo actual de comunicaciones.
- La gran mayoría de aplicaciones que utilizamos en la vida cotidiana en internet utilizan una aplicación web.
- La mayoría de las aplicaciones maneja información sensible o confidencial de sus usuarios.
- Un problema que tiene el desarrollo de aplicaciones es el “time to market”, lo que no permite realizar revisiones adecuadas de seguridad.

Vulnerabilidades web

- Hoy en día las herramientas se han especializado en buscar vulnerabilidades específicamente en aplicaciones web, lo que ha permitido crear una categoría de soluciones especialistas en este ámbito.
- Gartner ha creado una categoría denominada AST (Application Security Testing) que engloba a todas las compañías que tienen productos en este mercado.
- Es importante destacar que esta categoría no contempla las herramientas que buscan vulnerabilidades a un sistema operativo.

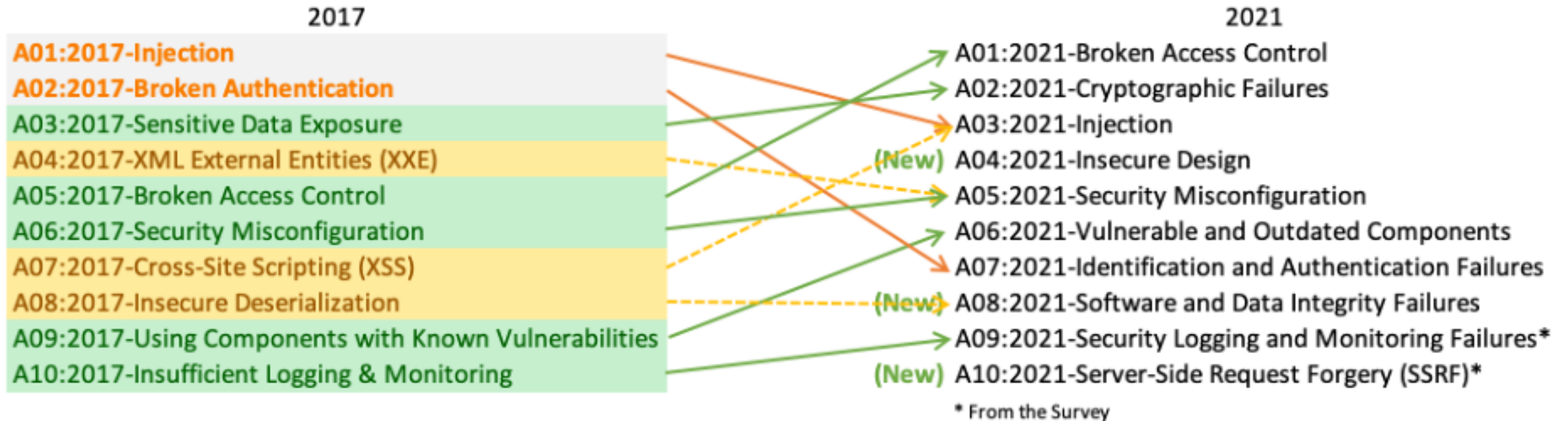
- **Hacking web**

- Arquitectura de una aplicación web:



OWASP Top 10

- El OWASP Top 10 es un documento de concientización estándar para desarrolladores y seguridad de aplicaciones web. Representa un amplio consenso sobre los riesgos de seguridad más críticos para las aplicaciones web.



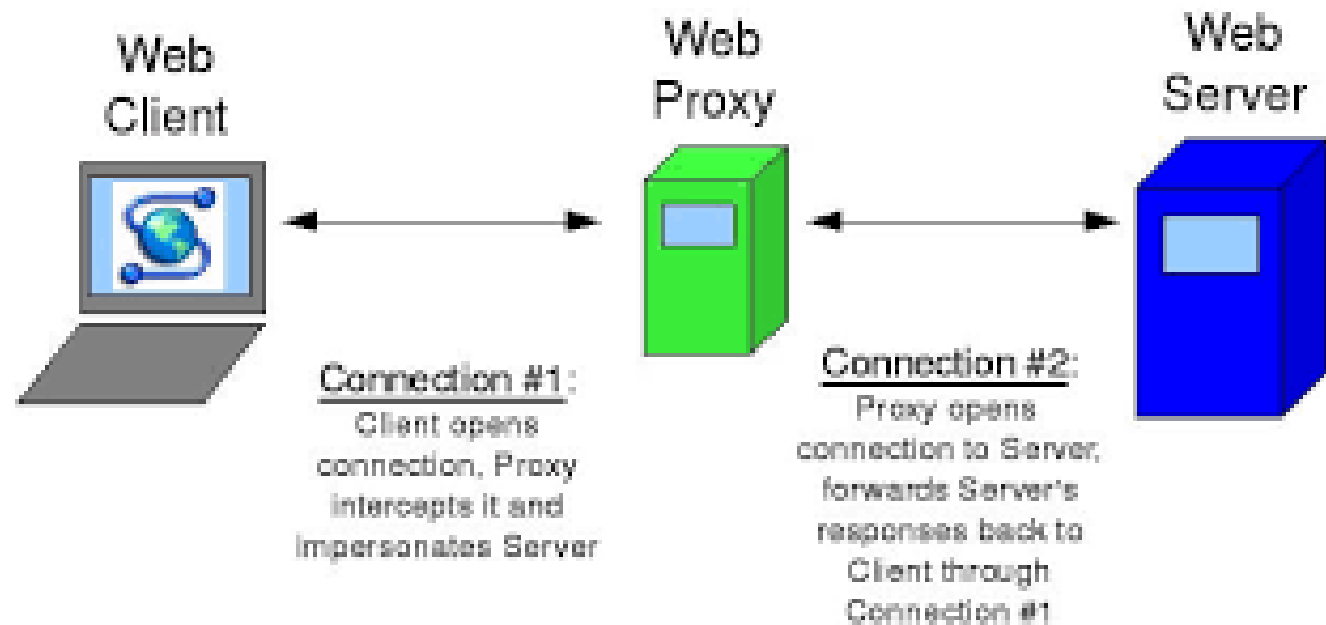
Hacking web

Conexión directa: en este caso se envían códigos a la aplicación web a través de las diferentes entradas de datos, con el propósito de medir la respuesta de la aplicación y validar los controles de seguridad



Hacking Web

Proxy: consiste en capturar el tráfico del cliente y/o la respuesta del servidor para realizar visualización de datos o alteración de estos y así validar la respuesta de la aplicación.





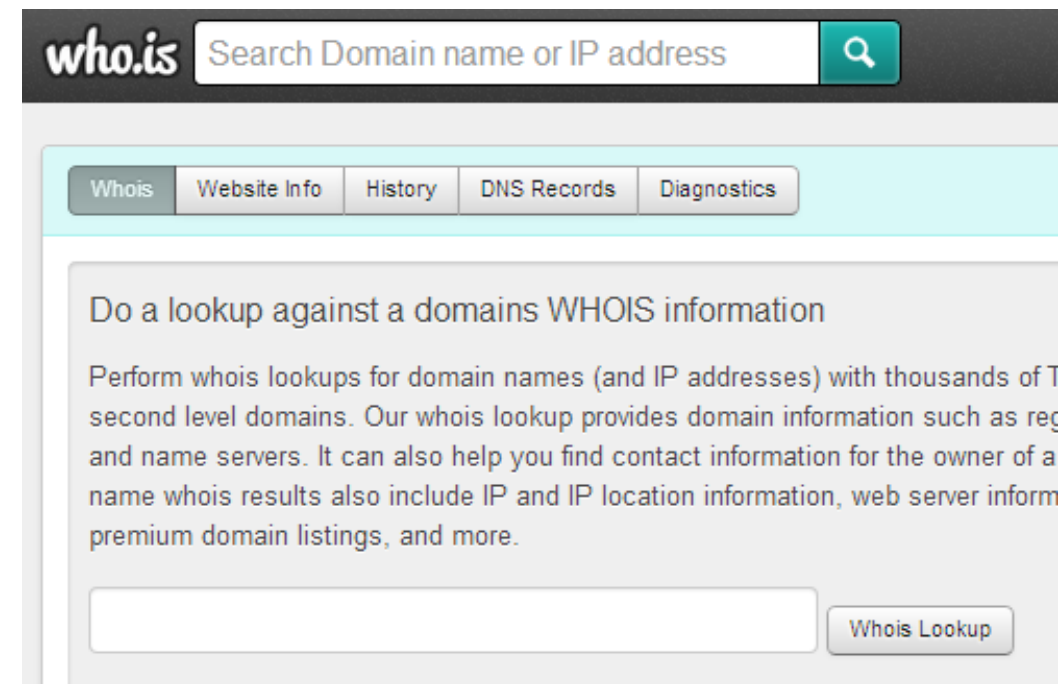
02

Reconocimiento

Reconocimiento

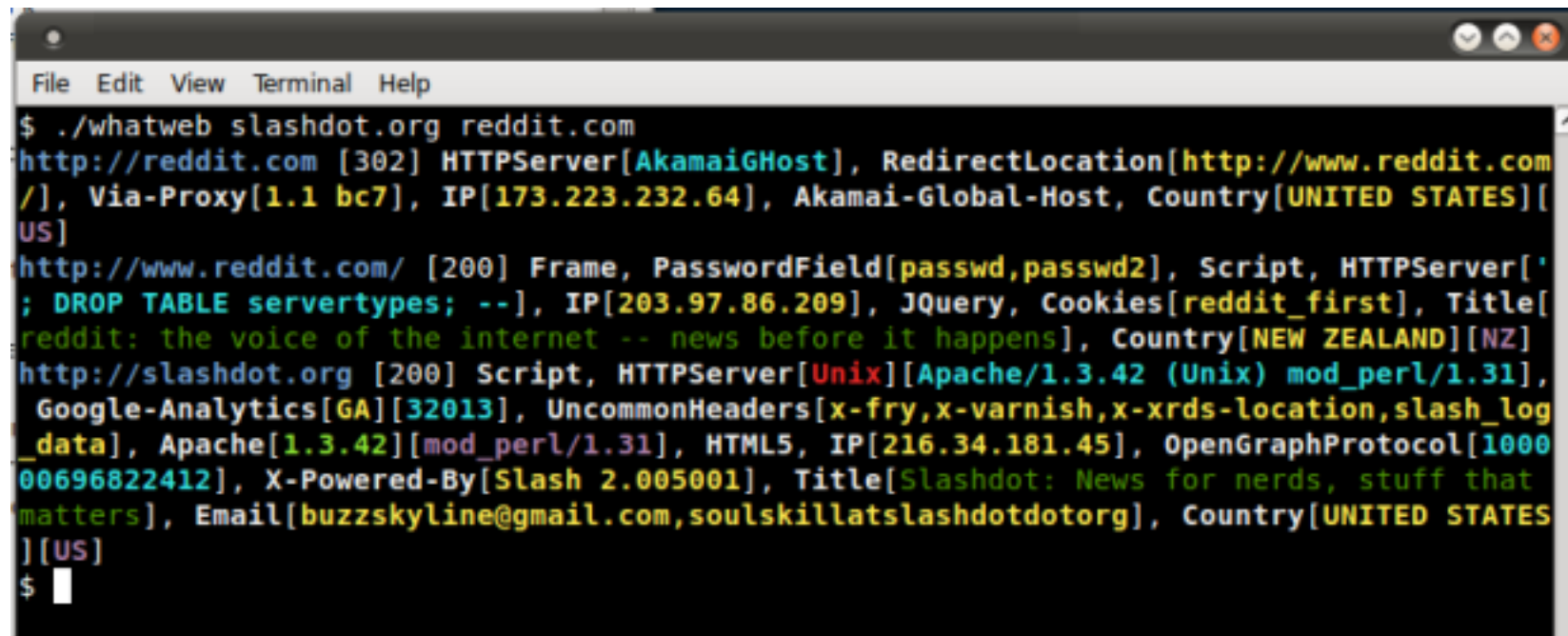
Footprinting a servidores web:

- El primer paso en un servicio de Ethical Hacking a un servicio web es conocer el tipo y versión de servidor web sobre el cual está montada la aplicación, para esto existen dos herramientas que se pueden utilizar, la primera es:
- Whois: <http://who.is/whois/>



Reconocimiento

- Reconocimiento de servidores web:
- La segunda herramienta más utilizada para realizar reconocimiento en aplicaciones web es **whatweb**



```
File Edit View Terminal Help
$ ./whatweb slashdot.org reddit.com
http://reddit.com [302] HTTPServer[AkamaiGHost], RedirectLocation[http://www.reddit.com/], Via-Proxy[1.1 bc7], IP[173.223.232.64], Akamai-Global-Host, Country[UNITED STATES][US]
http://www.reddit.com/ [200] Frame, PasswordField[passwd,passwd2], Script, HTTPServer['; DROP TABLE servertypes; --'], IP[203.97.86.209], JQuery, Cookies[reddit_first], Title[reddit: the voice of the internet -- news before it happens], Country[NEW ZEALAND][NZ]
http://slashdot.org [200] Script, HTTPServer[Unix][Apache/1.3.42 (Unix) mod_perl/1.31], Google-Analytics[GA][32013], UncommonHeaders[x-fry,x-varnish,x-xrds-location,slash_log_data], Apache[1.3.42][mod_perl/1.31], HTML5, IP[216.34.181.45], OpenGraphProtocol[100000696822412], X-Powered-By[Slash 2.005001], Title[Slashdot: News for nerds, stuff that matters], Email[buzzskyline@gmail.com,soulskillatlashdotdotorg], Country[UNITED STATES][US]
$
```

Reconocimiento

- **Métodos en aplicaciones web**
- **GET:** Pasa los parámetros a la aplicación web a través de la propia URL. Toma todas las entradas del formulario y las agrega a la URL. Si ingresa su nombre de usuario y contraseña y estos valores se pasan al servidor a través del método GET, cualquier persona en el servidor web puede recuperar el nombre de usuario y la contraseña de los archivos de registro de Apache o IIS.
- **POST:** Se utiliza para recuperar datos del servidor, pero pasa el contenido a través del cuerpo de la solicitud. Los datos del usuario están separados del encabezado.

• Métodos en aplicaciones web

name	value
GET	/search?q=Kali+Linux&q=0.9,*/*;q=0.8
Host	www.bing.com
User-Agent	Mozilla/5.0 (X11; U; Linux i686; en-US; rv:1.9.0.15) Gecko/2009102815 Ubuntu/9.04 (jaunty) ...
Accept	text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language	en-us,en;q=0.5
Accept-Encoding	gzip,deflate
Accept-Charset	ISO-8859-1,utf-8;q=0.7,*/*;q=0.7
Keep-Alive	300
Proxy-Connection	keep-alive
Referer	http://www.bing.com/
Cookie	MUID=3ED2E7BAFA8A60B7245AE17DFE8A6375; SRCHD=AF=NOFORM; SRCHUID=V=2&GUID=...

Parameter passed via the URL when using GET method

```
POST http://intranet.com:80/portal/index.php HTTP/1.1
Host: Webfarm1
User-Agent: Mozilla/5.0 (X11; U; Linux i686; en-US; rv:1.9.2.24) Gecko/20111103 Firefox/3.6.24
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Accept-Encoding: gzip,deflate
Accept-Charset: ISO-8859-1,utf-8;q=0.7,*/*;q=0.7
Keep-Alive: 115
Proxy-Connection: keep-alive
Referer: http://intranet.com/portal
Content-length: 62

username=admin&password=test&imageField2.x=26&imageField2.y=10
```

Parameters passed in the body of the HTTP request when using POST method

Reconocimiento

- **Métodos en aplicaciones web (cont.)**
- **HEAD:** Se utiliza para identificar el tipo de servidor, ya que este solo responde con el encabezado HTTP sin enviar ninguna carga útil. Es una forma rápida de averiguar la versión del servidor y la fecha.
- **TRACE:** Se utiliza para identificar cualquier alteración de la solicitud por parte de dispositivos intermediarios, como servidores proxy y firewalls. Algunos servidores proxy editan el encabezado HTTP cuando los paquetes lo pasan, y esto se puede identificar utilizando el método TRACE.

Reconocimiento

- Script para detección de métodos HTTP

```
root@kali:~# nmap --script http-methods 10.0.2.67 -p 80 -sV
Starting Nmap 7.70 ( https://nmap.org ) at 2018-10-15 00:16 UTC
Nmap scan report for 10.0.2.67
Host is up (0.0024s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.2.8 ((Ubuntu) DAV/2)
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
MAC Address: 08:00:27:E9:78:C0 (Oracle VirtualBox virtual NIC)
```

A black and white photograph of a woman in a server room. She is standing in a narrow aisle between rows of server racks. She is holding a tablet in her left hand and pointing with her right index finger at a label on one of the server racks. The room is dimly lit, with bright rectangular lights on the ceiling. The server racks are filled with various electronic components and cables.

03

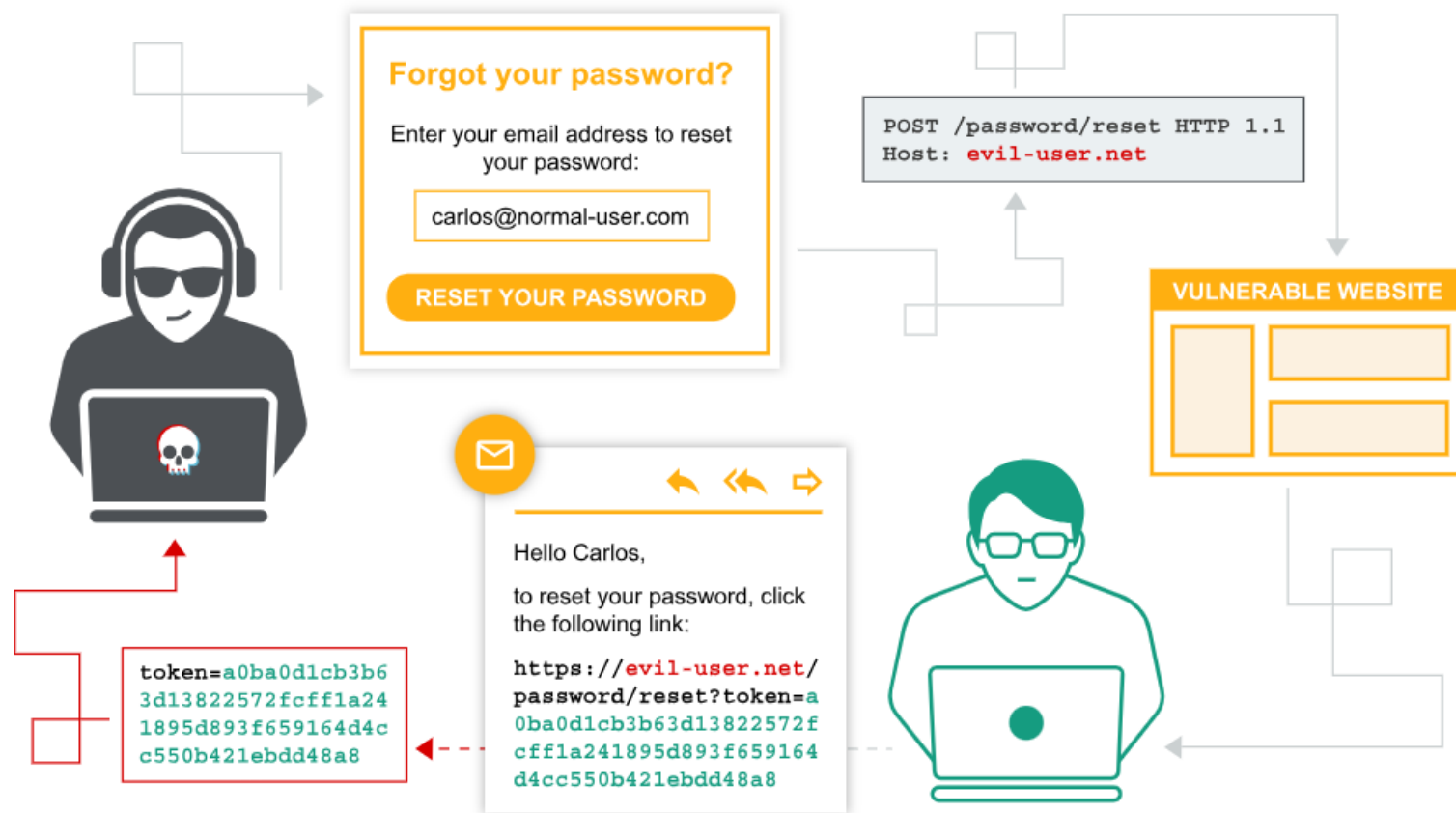
Hacking de aplicaciones web

Hacking web

Autenticación

El impacto de las vulnerabilidades de autenticación puede ser muy severo. Una vez que un atacante ha pasado por alto la autenticación o ha ingresado por la fuerza bruta en la cuenta de otro usuario, tiene acceso a todos los datos y funciones que tiene la cuenta comprometida. Si pueden comprometer una cuenta con muchos privilegios, como un administrador del sistema, podrían tomar el control total de toda la aplicación.

- Hacking web
- Autenticación



Hacking web

Path Traversal

Esta vulnerabilidad, también se conoce como “directory traversal”. Permite a un atacante leer archivos arbitrarios en el servidor que ejecuta una aplicación.

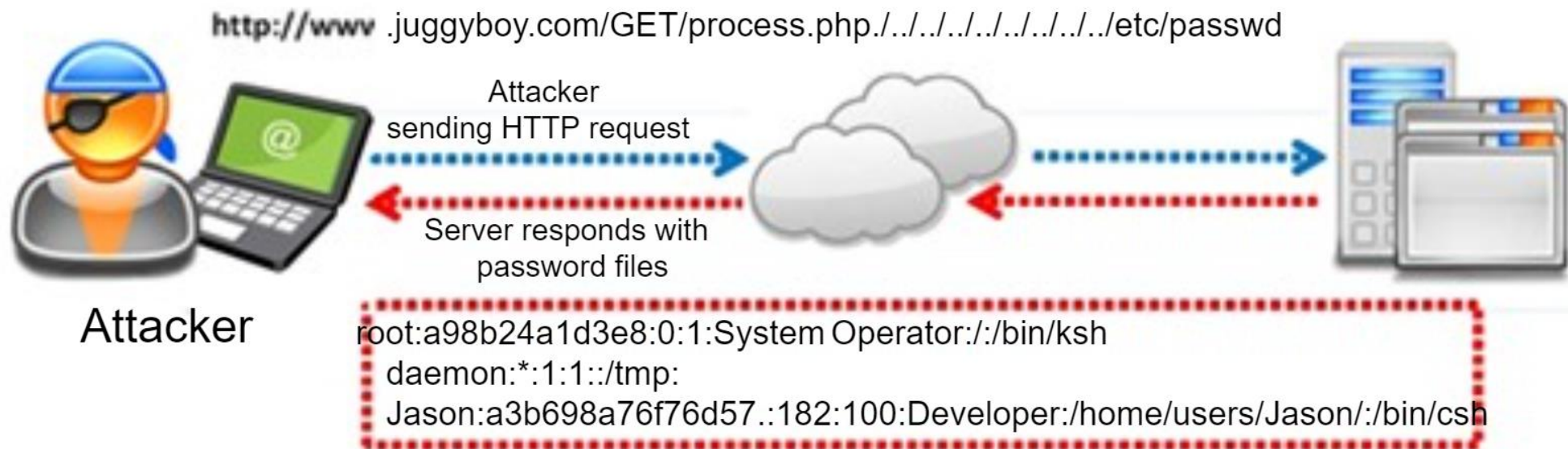
Esto podría incluir:

- Código y datos de la aplicación.
- Credenciales para sistemas back-end.
- Archivos sensibles del sistema operativo.

En algunos casos, un atacante podría escribir en archivos arbitrarios en el servidor, lo que le permitiría modificar los datos o el comportamiento de la aplicación y, en última instancia, tomar el control total del servidor.

• Hacking web

- Esta vulnerabilidad permite a un atacante acceder a directorios restringidos que pueden incluir archivos de configuración, usuarios, contraseñas, etc.
- El atacante puede manipular la entrada de variables de una aplicación web mediante la técnica llamada “dot-dot-slash ../”



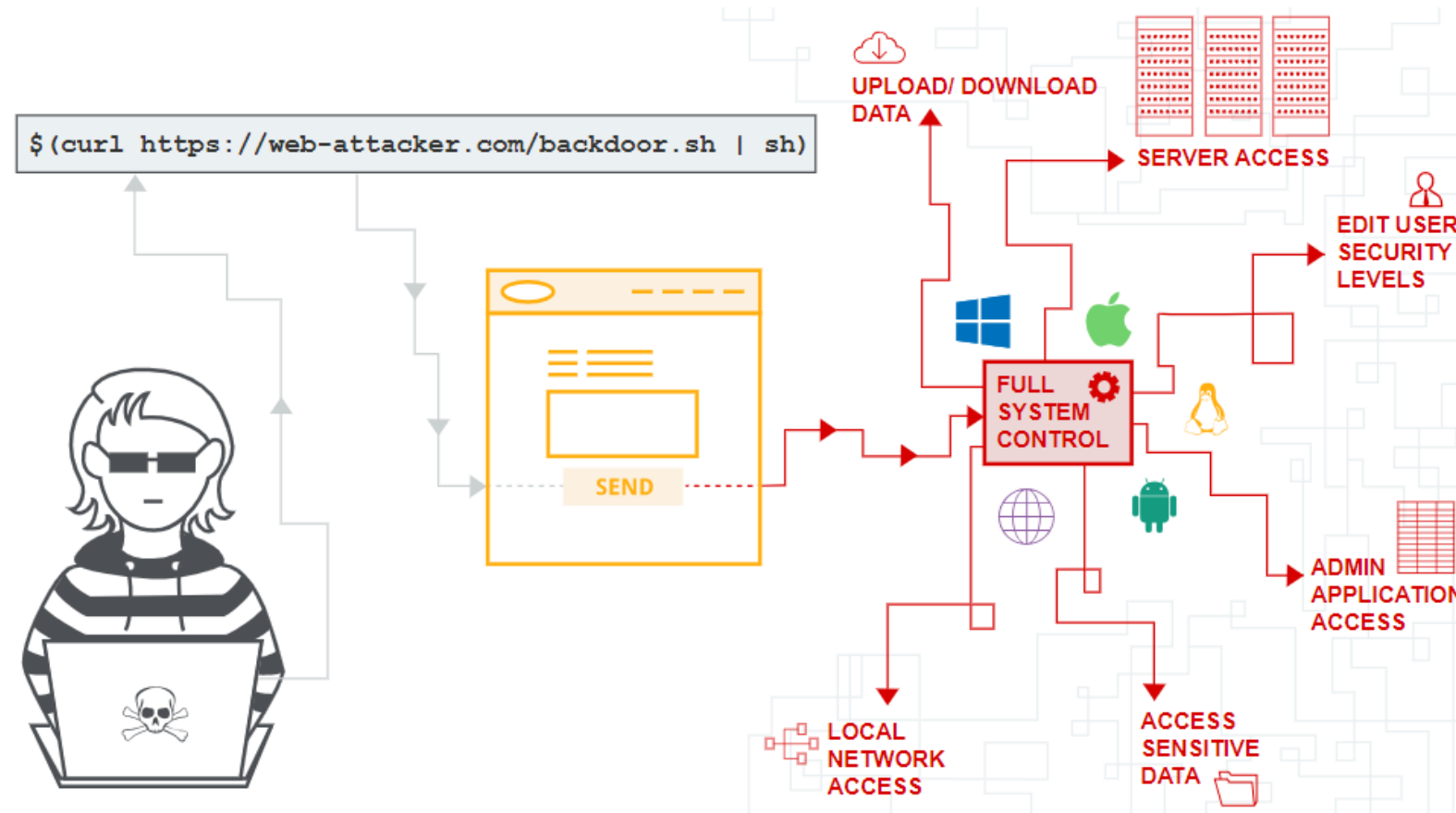
Hacking web

Inyección de comandos

Permite a un atacante ejecutar comandos arbitrarios del sistema operativo (SO) en el servidor que ejecuta una aplicación y, por lo general, compromete por completo la aplicación y todos sus datos. Muy a menudo, un atacante puede aprovechar una vulnerabilidad de inyección de comandos del sistema operativo para comprometer otras partes de la infraestructura.

- **Hacking web**

- Inyección de comandos de sistema operativo:

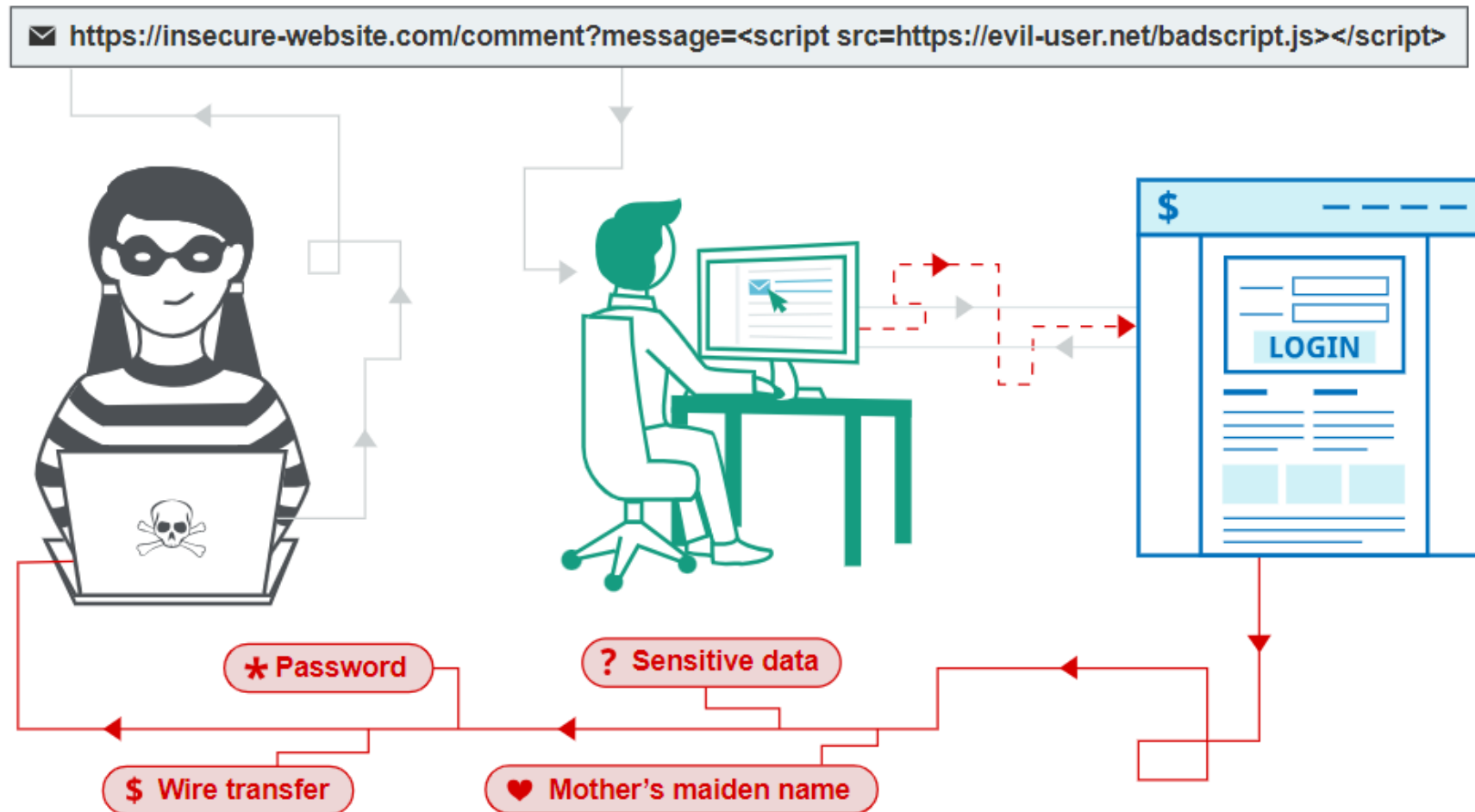


Hacking web

Cross site scripting

Esto ocurre cuando una aplicación incluye datos que no son de confianza en una nueva página web sin la validación o el escape adecuados, o actualiza una página web existente con datos proporcionados por el usuario mediante una API de navegador que puede crear HTML o JavaScript. XSS permite a los atacantes ejecutar scripts en el navegador de la víctima que pueden secuestrar sesiones de usuario, desfigurar sitios web o redirigir al usuario a sitios maliciosos.

- Hacking web
- Cross site scripting:

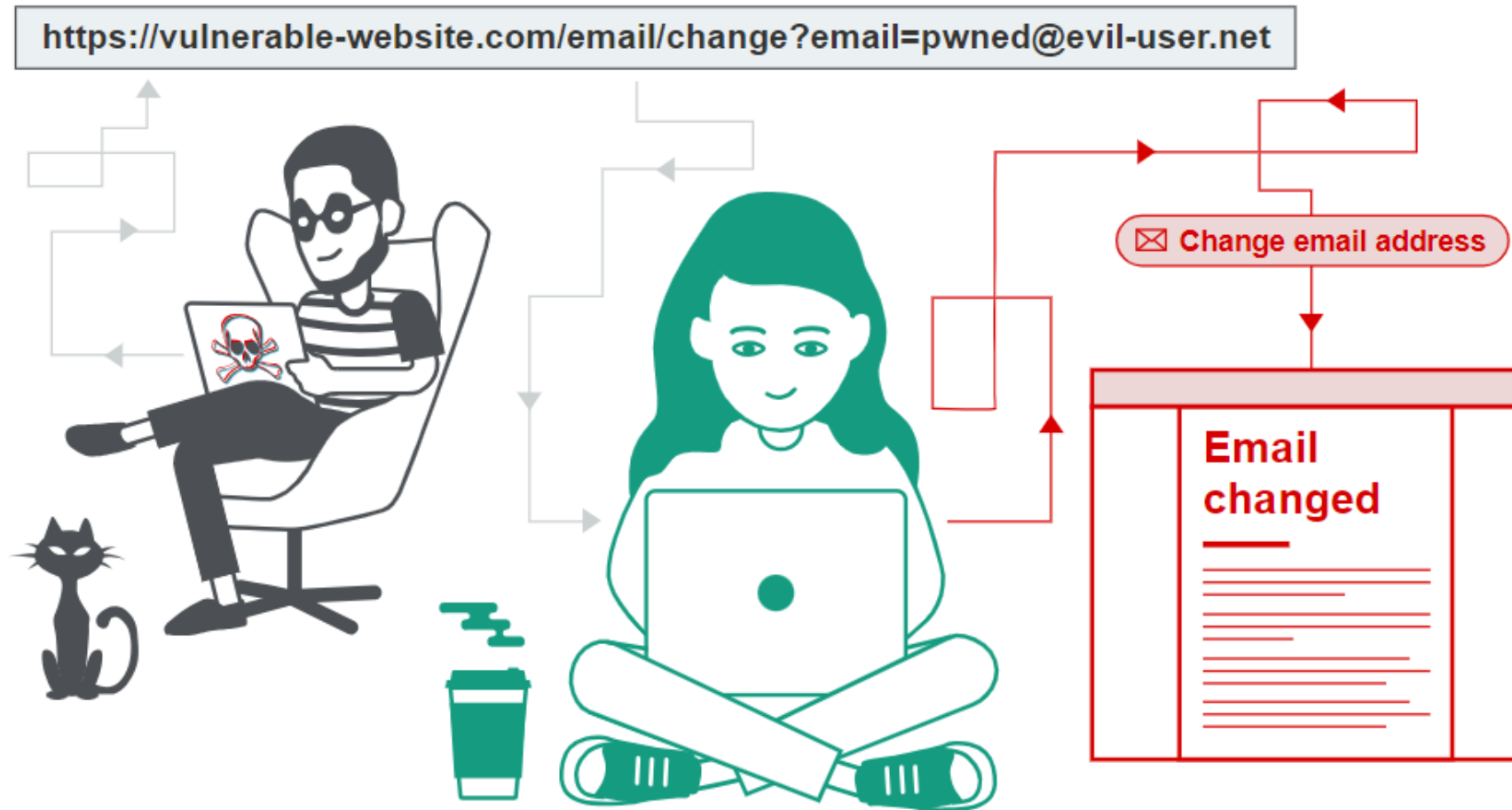


Hacking web

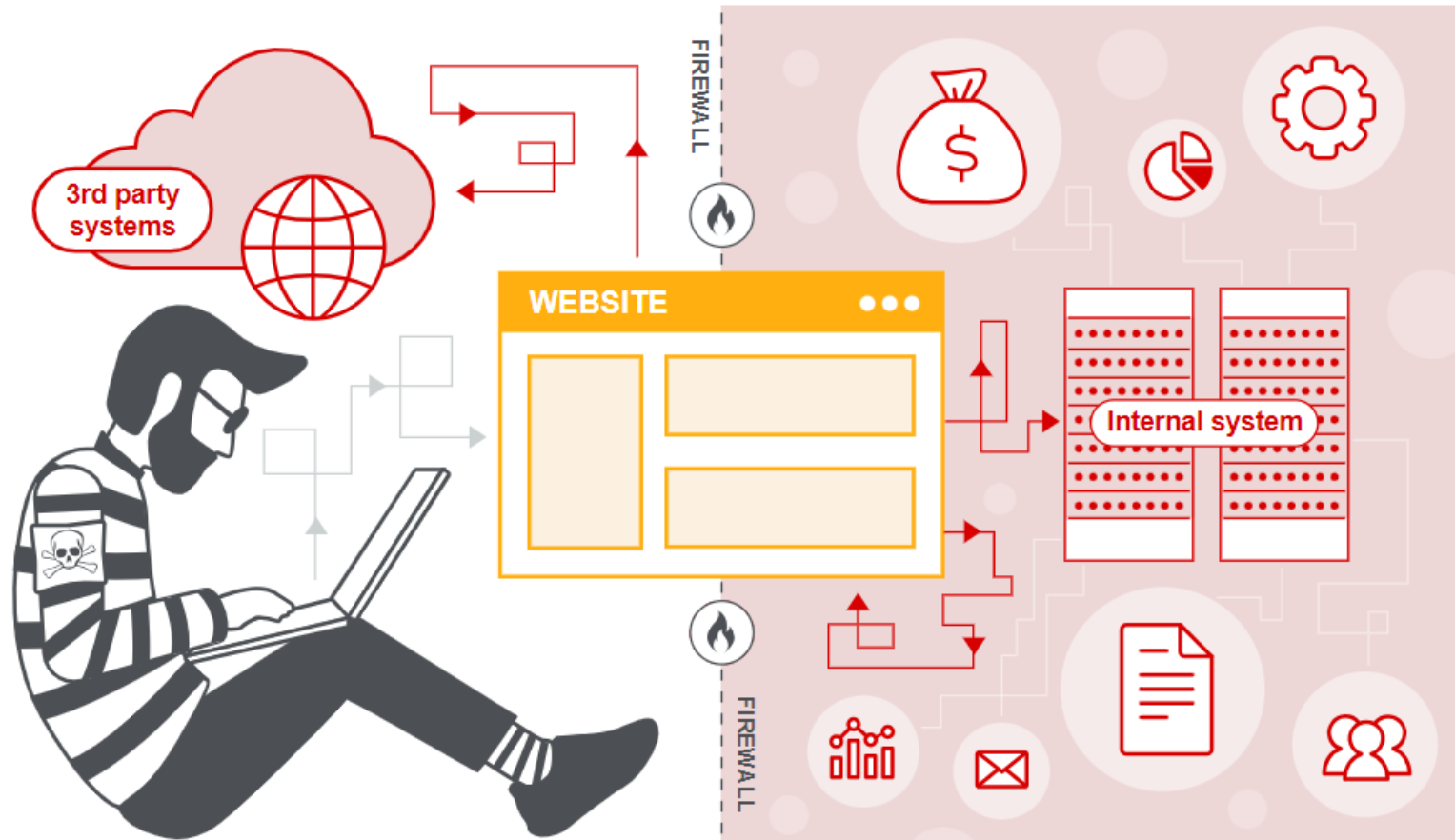
Cross Site Request Forgery (CSRF)

La falsificación de solicitudes entre sitios (también conocida como CSRF) es una vulnerabilidad de seguridad web que permite a un atacante inducir a los usuarios a realizar acciones que no pretenden realizar. Permite a un atacante eludir parcialmente la misma política de origen, que está diseñada para evitar que diferentes sitios web interfieran entre sí.

- **Hacking web**
- Cross Site Request Forgery:



- **Hacking web**
- Server Side Request Forgery:



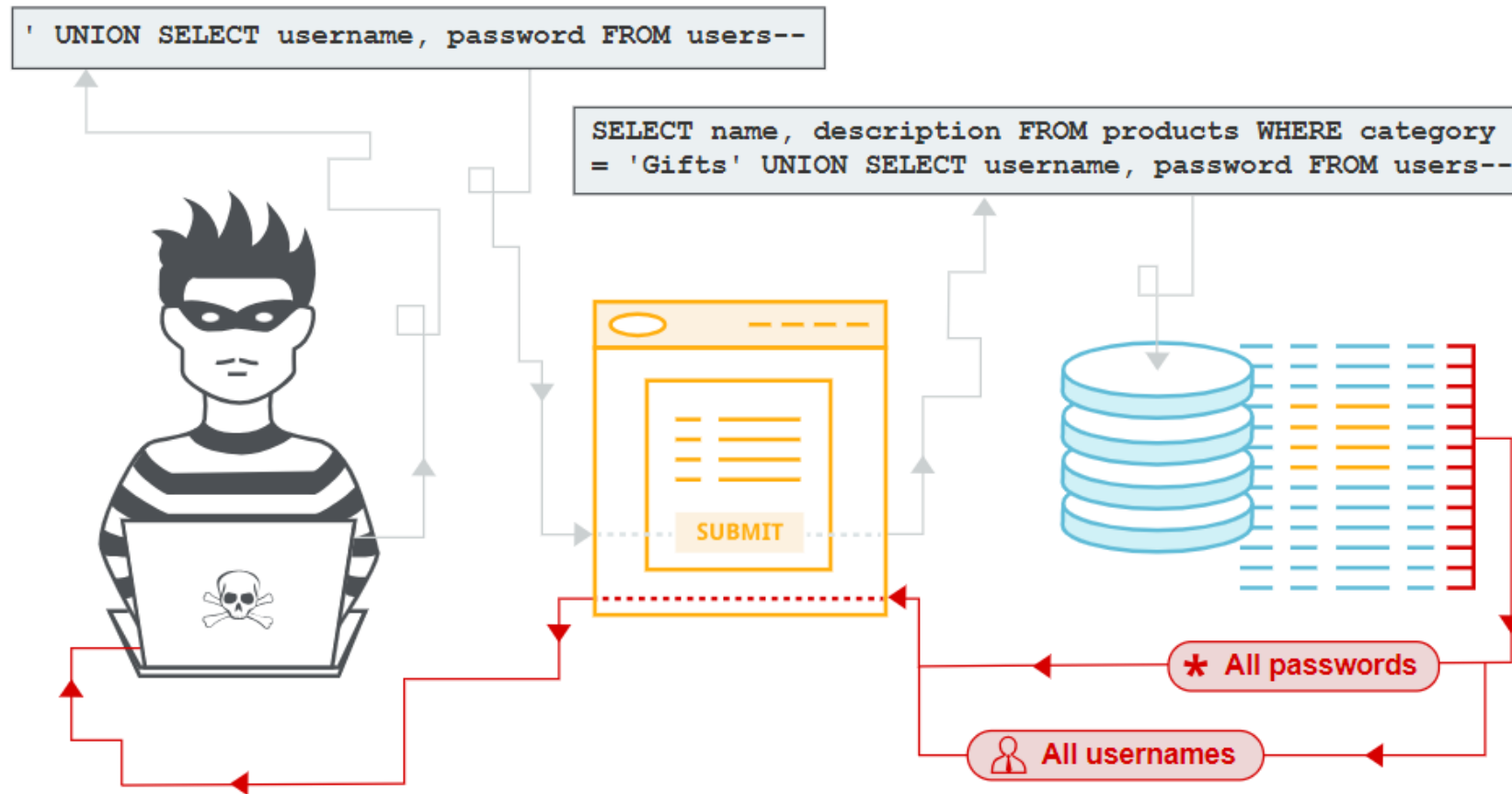
Hacking web

Inyección SQL

La falsificación de solicitudes del lado del servidor es una vulnerabilidad de seguridad web que permite a un atacante hacer que la aplicación del lado del servidor realice solicitudes a una ubicación no deseada.

En un ataque SSRF típico el atacante podría hacer que el servidor establezca una conexión con servicios exclusivamente internos dentro de la infraestructura de la organización. En otros casos, pueden obligar al servidor a conectarse a sistemas externos arbitrarios. Esto podría filtrar datos confidenciales, como credenciales de autorización.

- Hacking web
- Inyección SQL:





04

Conclusiones

Conclusiones

- Las aplicaciones web son esenciales en la vida diaria y, debido a la información sensible que manejan, son objetivos frecuentes de ataques cibernéticos.
- El OWASP Top 10 es una herramienta clave para identificar y mitigar las vulnerabilidades más críticas en el desarrollo de aplicaciones web.
- Las vulnerabilidades como inyección SQL, XSS y Path Traversal pueden ser explotadas para comprometer sistemas y acceder a datos sensibles.
- El reconocimiento de servidores y métodos HTTP es un paso fundamental para evaluar la seguridad de una aplicación web.

DuocUC[®]

CERCANÍA. LIDERAZGO. FUTURO.

(duoc.cl)

7 AÑOS
ACREDITADO



DESDE AGOSTO 2017 HASTA AGOSTO 2024.
DOCENCIA DE PREGRADO. GESTIÓN
INSTITUCIONAL. VINCULACIÓN CON EL MEDIO.